

BCAC 0029
CYBER SECURITY AND CYBER
LAWS

1. Introduction to Information Systems

- An **Information System (IS)** is a structured combination of **people, hardware, software, data, and procedures** that collects, processes, stores, and distributes information to support **decision-making, coordination, control, analysis, and visualization** in an organization.

Components of an Information System

- **Hardware** – Computers, servers, network devices, input/output devices
- **Software** – Operating systems, application software
- **Data** – Raw facts that are processed into useful information
- **People** – End users, managers, IT professionals
- **Procedures** – Rules and processes for using the system

Objectives of Information Systems

- 1. Improve Organizational Efficiency-** Information systems automate routine tasks and streamline business processes. This reduces manual effort, minimizes errors, and increases overall productivity.
- 2. Support Managerial Decision-Making-** Information systems provide timely, accurate, and relevant information to managers. This helps in planning, controlling, and making effective decisions.
- 3. Enhance Communication-** Information systems enable fast and reliable communication among employees, departments, and external partners. They improve coordination and collaboration within the organization.
- 4. Maintain Accurate Records-** Information systems store data systematically in databases, ensuring accuracy, consistency, and easy retrieval of records whenever required.
- 5. Provide Competitive Advantage-** Information systems help organizations respond quickly to market changes, improve customer service, and innovate, giving them an edge over competitors.

2. Types of Information Systems

- Information systems are classified based on **organizational level and purpose**.
- **1. Transaction Processing Systems (TPS)**
 - Handle day-to-day business transactions
 - Examples: Payroll system, billing system, order processing
- **2. Management Information Systems (MIS)**
 - Provide summarized reports for middle management
 - Support routine decision-making
 - Examples: Sales reports, inventory reports

2. Types of Information Systems

- **3. Decision Support Systems (DSS)**
 - Assist managers in complex decision-making
 - Use analytical models and data analysis
 - Examples: Budget forecasting, risk analysis
- **4. Executive Information Systems (EIS)**
 - Designed for top-level executives
 - Provide graphical dashboards and trends
 - Examples: Profit analysis, strategic planning
- **5. Knowledge Management Systems (KMS)**
 - Capture, store, and share organizational knowledge
 - Examples: Document repositories, learning systems

Transaction Processing System (TPS)

- A **Transaction Processing System (TPS)** is an information system that handles **day-to-day, routine business transactions** efficiently and accurately. These transactions are repetitive and occur frequently in an organization.
- **Key Characteristics**
 - High volume of data processing
 - Speed and accuracy are critical
 - Supports operational-level employees
 - Handles structured and predefined tasks
- **Functions of TPS**
 - Data collection and input
 - Data processing (calculations, sorting)
 - Data storage in databases
 - Transaction reporting

- **Importance**
- TPS ensures smooth daily operations of an organization. Without TPS, basic business activities such as sales, payments, and salary processing would be slow and error-prone.
- **Real-Time Examples**
- **Payroll System** – Calculates employee salaries, deductions, and bonuses
- **Billing System** – Generates invoices for customers
- **Order Processing System** – Records customer orders in e-commerce sites like Amazon
- **ATM Transactions** – Cash withdrawal, balance enquiry

Management Information Systems (MIS)

- A **Management Information System (MIS)** provides **summarized and structured reports** to middle-level management to support **routine decision-making and control**.
- **Key Characteristics**
- Uses data generated by TPS
- Provides periodic reports (daily, weekly, monthly)
- Focuses on internal operations
- Supports structured decisions

- **Functions of MIS**

- Data summarization
- Performance monitoring
- Report generation
- Management control

- **Importance**

- MIS helps managers monitor organizational performance, identify problems, and take corrective actions.

- **Real-Time Examples**

- **Sales Performance Reports** for monthly targets
- **Inventory Status Reports** in retail stores
- **Attendance and Leave Reports** in HR departments
- **Production Reports** in manufacturing companies

Decision Support Systems (DSS)

- A **Decision Support System (DSS)** is an interactive system that assists managers in making **complex, non-routine, and semi-structured decisions** using data analysis and models.
- **Key Characteristics**
 - Combines data, analytical tools, and models
 - Supports what-if analysis
 - Flexible and user-friendly
 - Used by managers and analysts

- **Functions of DSS**

- Data analysis
- Scenario evaluation
- Forecasting and simulations
- Risk assessment

- **Importance**

- DSS improves decision quality by reducing uncertainty and helping managers evaluate multiple alternatives before taking action.

- **Real-Time Examples**

- **Budget Forecasting Systems** in finance departments
- **Risk Analysis Tools** used by banks
- **Demand Forecasting Systems** in supply chain management
- **Investment Decision Tools** in stock markets

Executive Information Systems (EIS)

- An **Executive Information System (EIS)** is designed specifically for **top-level executives** to support **strategic decision-making** by providing summarized, graphical, and trend-based information.
- **Key Characteristics**
 - Highly summarized information
 - Graphical dashboards and charts
 - Easy to use
 - Focus on long-term goals

- **Functions of EIS**

- Strategic performance monitoring
- Trend analysis
- Competitive analysis
- Goal tracking

- **Importance**

- EIS helps top management quickly understand the overall health of the organization and make long-term strategic decisions.

- **Real-Time Examples**

- Profit and Loss Dashboards
- Market Share Analysis Reports
- Company Growth Trend Graphs
- Strategic Planning Systems used by CEOs

Knowledge Management Systems (KMS)

- A **Knowledge Management System (KMS)** captures, stores, organizes, and shares **organizational knowledge** to improve learning, innovation, and decision-making.
- **Key Characteristics**
 - Stores explicit and tacit knowledge
 - Encourages knowledge sharing
 - Supports learning and collaboration
 - Improves organizational memory

- **Functions of KMS**

- Knowledge creation
- Knowledge storage
- Knowledge retrieval
- Knowledge sharing

- **Importance**

- KMS prevents knowledge loss, improves employee skills, and supports innovation by making information easily accessible.

- **Real-Time Examples**

- **Document Repositories** like SharePoint
- **Learning Management Systems (LMS)** in universities
- **Corporate Wikis**
- **Knowledge Bases** used by IT support teams

3. Development of Information Systems

The **development of information systems** involves a structured process to design, build, and implement systems that meet user requirements.

System Development Life Cycle (SDLC)

- **Planning-** Identify system goals and feasibility
- **Requirement Analysis-** Gather user and business requirements
- **System Design-** Create system architecture, data flow diagrams
- **Development-** Coding and system construction
- **Testing-** Detect and fix errors
- **Implementation-** Deploy system to users
- **Maintenance-** Ongoing updates and support

Importance of IS Development

- Ensures reliability and accuracy
- Reduces system failures
- Improves user satisfaction
- Enhances security and performance

4. CIA Model of Information Characteristics

The **CIA Model** is the foundation of **information security**, representing three key security goals.

1. Confidentiality

- Ensures information is accessible **only to authorized users**
- Prevents unauthorized disclosure

Techniques:

- Encryption
- Access control
- Authentication

2. Integrity

- Ensures information is **accurate, complete, and unaltered**
- Protects data from unauthorized modification

Techniques:

- Hashing
- Digital signatures
- Checksums

3. Availability

- Ensures information is **available when needed**
- Prevents service disruptions

Techniques:

- Backups
- Redundancy
- Disaster recovery systems

5. Introduction to Information Security

Information Security refers to the protection of information and information systems from **unauthorized access, use, disclosure, disruption, modification, or destruction**.

Objectives of Information Security

- Protect sensitive data
- Ensure business continuity
- Prevent cyber attacks
- Maintain trust and reputation

Areas of Information Security

- Network security
- Application security
- Data security
- Physical security

Areas of Information Security- Network security

- Network security focuses on protecting **computer networks and data transmitted over networks** from unauthorized access, misuse, or attacks.
- **Key aspects:**
 - Prevents hacking, malware, and unauthorized intrusions
 - Monitors incoming and outgoing network traffic
 - Protects both internal and external networks
- **Common tools & techniques:**
 - Firewalls
 - Intrusion Detection/Prevention Systems (IDS/IPS)
 - Virtual Private Networks (VPN)
 - Network segmentation
- **Example:**
Blocking unauthorized users from accessing an organization's internal network.

Application Security

- Application security deals with protecting **software applications** from security threats throughout their lifecycle (design, development, deployment, and maintenance).
- **Key aspects:**
 - Identifies and fixes vulnerabilities in applications
 - Prevents attacks like SQL injection and cross-site scripting (XSS)
 - Ensures secure coding practices
- **Common tools & techniques:**
 - Secure coding standards
 - Application firewalls (WAF)
 - Regular patching and updates
 - Code reviews and penetration testing
- **Example:**
Protecting a web application from hackers trying to steal user login credentials.

Data Security

- Data security focuses on protecting **data from unauthorized access, alteration, or destruction**, whether the data is stored, transmitted, or processed.
- **Key aspects:**
 - Ensures confidentiality, integrity, and availability of data
 - Protects sensitive data such as personal and financial information
 - Controls who can access data and how it is used
- **Common tools & techniques:**
 - Encryption
 - Access control and authentication
 - Data backups
 - Data loss prevention (DLP)
- **Example:**
Encrypting customer data stored in a database to prevent data breaches.

Physical Security

- Physical security protects **physical assets** such as computers, servers, networking devices, and data centers from physical threats.
- **Key aspects:**
 - Prevents theft, damage, or unauthorized physical access
 - Protects infrastructure from natural disasters and accidents
 - Ensures secure working environments
- **Common tools & techniques:**
 - CCTV cameras
 - Biometric access controls
 - Security guards
 - Fire detection and suppression systems
- **Example:**
Restricting access to a server room using biometric authentication.

6. Need for Information Security

Information security is essential due to the increasing **dependence on digital systems**.

Reasons for Information Security

- Protection of sensitive data
- Prevention of cyber crimes
- Compliance with laws and regulations
- Business continuity
- Protection against data breaches

Threats to Information

- Malware and ransomware
- Phishing attacks
- Insider threats
- Denial of Service (DoS) attacks

Malware and Ransomware

Malware is malicious software designed to damage, disrupt, or gain unauthorized access to computer systems.

- **Types of malware:**

- Virus
- Worm
- Trojan horse
- Spyware

Ransomware is a type of malware that **encrypts data** and demands a ransom to restore access.

- **Impact:**

- Data loss or corruption
- System slowdown or failure
- Financial loss

- **Example:**

A ransomware attack locks all files in a company's system and demands payment for decryption.

Phishing Attacks

- Phishing is a **social engineering attack** where attackers trick users into revealing sensitive information such as passwords, credit card numbers, or OTPs.
- **Common methods:**
 - Fake emails
 - Fraudulent websites
 - SMS phishing (smishing)
 - Voice calls (vishing)
- **Impact:**
 - Identity theft
 - Unauthorized account access
 - Financial fraud
- **Example:**

An email pretending to be from a bank asks users to click a link and enter login details.

Insider Threats

- Insider threats come from **people within the organization**, such as employees, contractors, or partners, who misuse their authorized access.
- **Types:**
 - Malicious insiders (intentional data theft)
 - Negligent insiders (careless actions)
 - Compromised insiders (accounts hacked by attackers)
- **Impact:**
 - Data leakage
 - Intellectual property theft
 - Damage to organizational reputation
- **Example:**

An employee copies confidential company data and shares it with competitors.

Denial of Service (DoS) Attacks

- A DoS attack aims to **make a system, server, or network unavailable** to legitimate users by overwhelming it with excessive traffic or requests.
- **Types:**
 - DoS (single system attack)
 - Distributed DoS (DDoS) using multiple compromised systems
- **Impact:**
 - Website downtime
 - Service disruption
 - Loss of customer trust
- **Example:**

An attacker floods a company's website with fake requests, causing it to crash.

7. Cyber Security and Business Needs

- **Cyber Security** aligns technology protection with **business objectives**.
- **Importance for Businesses**
 - Protects customer data
 - Prevents financial losses
 - Ensures operational continuity
 - Maintains brand reputation
- **Business Impacts of Cyber Attacks**
 - Loss of customer trust
 - Legal penalties
 - Business downtime
 - Competitive disadvantage

- **Cyber Security Measures**

1. Firewalls and Intrusion Detection Systems- Firewalls control and filter network traffic, while intrusion detection systems monitor and identify unauthorized or suspicious activities.

2. Security Policies and Audits- Security policies define rules for protecting information, and audits regularly evaluate systems to ensure compliance and identify vulnerabilities.

3. Employee Awareness Training- This training educates employees about cyber threats, safe practices, and how to avoid attacks like phishing and social engineering.

4. Incident Response Planning- Incident response planning prepares organizations to quickly detect, respond to, and recover from security incidents with minimal damage.

8. Ethical and Professional Issues in Security

- Ethics and professionalism guide responsible behaviour in information security.

1. Privacy Violation

- Privacy violation occurs when personal or sensitive information is collected, accessed, or shared **without the individual's consent**.
- **Example:**
Accessing someone's personal emails or medical records without permission.

2. Unauthorized Access

- Unauthorized access refers to entering a computer system, network, or data **without proper permission or legal rights**.
- **Example:**
Using another person's login credentials to access confidential files.

3. Data Misuse

- Data misuse happens when authorized data is used **for purposes other than those intended**, often violating ethical or legal standards.
- **Example:**
Using customer data for marketing without their approval.

4. Intellectual Property Theft

- Intellectual property theft involves **stealing or copying protected creations** such as software, music, designs, or research without permission.
- **Example:**
Using pirated software or copying copyrighted content without credit.

Information Security Model

- CIA Triad & Security Services
- Confidentiality, Integrity, Availability
- Authentication, Authorization,
- Non-Repudiation

CIA Triad Overview

- The core principles of information security

- Confidentiality

- Integrity

- Availability

Confidentiality

- Ensures information is accessible only to authorized users
- Methods:
 - ✓ - Encryption
 - ✓ - Passwords
 - ✓ - Access control
 - ✓ Example: Bank account details

Integrity

- Ensures data is accurate and unaltered
- Methods:
 - ✓ - Hashing
 - ✓ - Digital signatures
 - ✓ - Checksums
 - ✓ Example: Student marks

Availability

- Ensures data is available when needed
- Methods:
 - ✓ - Backups
 - ✓ - Redundancy
 - ✓ - DoS protection
 - ✓ Example: Online banking

Authentication

- Verifies identity of user- Who are you?
- Methods:
 - ✓ - Passwords
 - ✓ - OTP
 - ✓ - Biometrics

Authorization

- Defines access rights- What can you do?
- ✓ Role-based access control
- ✓ Example: Student vs Admin

Non-Repudiation

- Prevents denial of actions
- Methods:
 - ✓ - Digital signatures
 - ✓ - Audit logs
 - ✓ Example: Online transactions

- **CIA Triad ensures core security**
- **Authentication verifies identity**
- **Authorization controls access**
- **Non-repudiation ensures accountability**

Aspects of Information Security

- The aspects of Information Security describe the **different dimensions through which security is implemented and managed** in an organization. These aspects focus on **how security is applied in practice**.

1. Administrative (Managerial) Aspect

- This aspect deals with **policies, procedures, and governance** required to manage information security.
- **Technical orientation:**
 - Security policies, standards, and guidelines
 - Risk assessment and risk management frameworks
 - Compliance with standards such as **ISO/IEC 27001**
- **Purpose:**
Defines *rules and responsibilities* for protecting information.

2. Technical Aspect

- The technical aspect focuses on **technological controls** used to protect information systems.
- **Technical orientation:**
 - Firewalls, intrusion detection and prevention systems (IDS/IPS)
 - Encryption, secure protocols, and authentication mechanisms
 - Secure OS configuration and application security controls
- **Purpose:**
Prevents, detects, and responds to technical attacks.

3. Physical Aspect

- This aspect ensures **physical protection of information assets.**
- **Technical orientation:**
 - Secure data centers, biometric access, CCTV surveillance
 - Protection of hardware against theft, fire, and natural disasters
 - Environmental controls such as temperature and power management
- **Purpose:**
 - Prevents physical damage and unauthorized physical access.

4. Operational Aspect

- The operational aspect deals with **day-to-day security operations**.
- **Technical orientation:**
 - Backup and recovery operations
 - Patch management and system updates
 - Incident response and change management procedures
- **Purpose:**
Ensures continuous and secure system operation.

5. Legal and Ethical Aspect

- This aspect addresses **laws, regulations, and ethical responsibilities** related to information security.
- **Technical orientation:**
 - Compliance with data protection laws (IT Act, GDPR)
 - Handling of intellectual property and privacy
 - Digital evidence and cyber crime regulations
- **Purpose:**
Avoids legal penalties and ensures ethical use of data.

6. Human Aspect

- The human aspect focuses on **user behavior and awareness**, which is often the weakest security link.
- **Technical orientation:**
 - Security awareness training and social engineering prevention
 - Access privilege management
 - Insider threat mitigation
- **Purpose:**
Reduces human-related security risks.

7. Strategic Aspect

- This aspect aligns information security with **organizational goals and long-term planning**.
- **Technical orientation:**
 - Security architecture planning
 - Business continuity and disaster recovery strategy
 - Security investment and resource allocation
- **Purpose:**
Ensures security supports business objectives.

Security Attacks: Active and Passive

- A **security attack** is any attempt to compromise the **confidentiality, integrity, or availability (CIA)** of information or information systems. Based on the nature of interaction with data, security attacks are broadly classified into **Passive attacks** and **Active attacks**.

Passive Attacks

- **Definition**
- A **passive attack** is an attack in which the attacker **only observes or monitors** the communication without altering the data. The main goal is **information gathering**, not system damage.
- **Key Characteristics**
- No modification of data
- Difficult to detect
- Targets **confidentiality**
- Attacker remains hidden

Types of Passive Attacks

- **a) Eavesdropping / Release of Message Contents**
- The attacker secretly listens to or reads the data being transmitted.
- **Example:**
- An attacker intercepts unencrypted emails over a public Wi-Fi network.
- Sniffing usernames and passwords sent in plain text using tools like packet sniffers.

- **b) Traffic Analysis**

- Even if data is encrypted, the attacker studies communication patterns such as frequency, size, and timing of messages.
- **Example:**
 - Observing heavy data flow between a client and a server to infer sensitive business operations.
 - Analyzing call duration and frequency to identify key communication partners.

Impact of Passive Attacks

- Leakage of sensitive information
- Privacy violation
- Can lead to future active attacks

Prevention Measures

- Data encryption
- Secure communication protocols (HTTPS, SSL/TLS)
- Network monitoring

Active Attacks

- **Definition**
- An **active attack** involves **modification, deletion, or disruption** of data or services. The attacker directly interferes with system operations.
- **Key Characteristics**
- Data is altered or destroyed
- Easier to detect
- Targets **integrity and availability**
- Causes direct damage

Types of Active Attacks

a) Masquerade Attack

- The attacker pretends to be a legitimate user.
- **Example:**
- Using stolen login credentials to access a banking system.
- Spoofing an IP address to gain unauthorized access.

b) Replay Attack

- Previously captured valid data is retransmitted to gain unauthorized access.
- **Example:**
- Reusing captured authentication messages to log into a system.
- Replaying old transaction requests in online systems.

Types of Active Attacks

- **c) Modification of Messages**

- Data is altered during transmission.

- **Example:**

- Changing the amount in an online fund transfer.
- Altering grades in a university database.

- **d) Denial of Service (DoS) Attack**

- The attacker disrupts services by overwhelming the system.

- **Example:**

- Flooding a server with excessive requests to make it unavailable.
- Distributed DoS (DDoS) attacks using botnets.

Impact of Active Attacks

- Data corruption
- System downtime
- Financial and reputational loss

Prevention Measures

- Firewalls and Intrusion Detection Systems (IDS)
- Strong authentication mechanisms
- Digital signatures and checksums
- Regular security audits

Comparison Between Passive and Active Attacks

Aspect	Passive Attack	Active Attack
Data alteration	No	Yes
Detectability	Very difficult	Easier
Primary target	Confidentiality	Integrity & Availability
System impact	Indirect	Direct
Examples	Eavesdropping, traffic analysis	DoS, masquerade, replay

Security Mechanisms and Services (X.800)

- The **X.800 recommendation** by **ITU-T** defines the **OSI Security Architecture**, which provides a structured framework to protect communication systems. It identifies **security services** (what is protected) and **security mechanisms** (how protection is provided).

Security Services (X.800)

- Security services enhance the security of data and systems by countering security attacks.
- **1.1 Authentication**
- Ensures the identity of users or the source of data is genuine.
- **Peer Entity Authentication:** Verifies identities during a session (prevents masquerade and replay attacks).
- **Data Origin Authentication:** Confirms the source of received data.
- *Example:* User login using credentials and OTP.

1.2 Access Control

- Prevents unauthorized access to system resources by enforcing permissions.
- Example: File access permissions and role-based access control.

1.3 Data Confidentiality

- Protects information from unauthorized disclosure.
- Types include:
 - Connection confidentiality
 - Connectionless confidentiality
 - Selective field confidentiality
 - Traffic flow confidentiality
- Example: Encrypting data using AES over HTTPS.

1.4 Data Integrity

- Ensures data is not altered during transmission or storage.
- Includes:
 - Connection integrity (with/without recovery)
 - Selective field integrity
 - Connectionless integrity
- Example: Hash functions and MACs.

1.5 Non-Repudiation

- Prevents sender or receiver from denying a communication.
- Non-repudiation of origin
- Non-repudiation of receipt
- Example: Digital signatures in online transactions.

Security Mechanisms (X.800)

Security mechanisms are techniques used to implement security services.

Specific Security Mechanisms

- ✓ Encipherment: Encrypts data for confidentiality
- ✓ Digital Signature: Provides authentication, integrity, non-repudiation
- ✓ Access Control Mechanisms: Enforce access policies
- ✓ Data Integrity Mechanisms: Detect data modification
- ✓ Authentication Exchange: Identity verification using protocols
- ✓ Traffic Padding: Hides traffic patterns
- ✓ Routing Control: Selects secure communication paths
- ✓ Notarization: Trusted third-party validation

Pervasive Security Mechanisms

- Trusted functionality
- Security labels
- Event detection
- Security audit trail
- Security recovery

The **X.800 security architecture** provides a clear and systematic approach to securing communication systems by defining **security services** and their supporting **mechanisms**. It forms the foundation for modern **network and information security models**.

X.800 Security Architecture (ISO 7498-2)

- The X.800 Security Architecture is a conceptual framework defined by ISO to describe how security is organized in a networked system, especially in the OSI model environment.
- It does not define algorithms or protocols, but explains how security is structured.
- Architecture Concept- X.800 says that any secure system can be understood using three connected layers:
- Threats → Protection Goals → Technical Controls
(Attacks) (Services) (Mechanisms)

Logical Flow of the Architecture

- Security Attacks**

Represent the **problem layer**.

They describe the different ways security can be violated.

- Security Services**

Represent the **solution layer**.

They define **what security must be provided** to stop attacks.

- Security Mechanisms**

Represent the **implementation layer**.

They define **how the security services are achieved** in real systems.

Relationship in Architecture

- One **attack** may require **multiple services**.
- One **service** may use **multiple mechanisms**.
- The architecture is **modular and layered**, so systems can mix and match services and mechanisms.

Architectural View (Text Diagram)

- +-----+
- | Security Attacks |

- +-----+



- +-----+
- | Security Services |

- +-----+



- +-----+
- | Security Mechanisms |

- +-----+

Purpose of the Architecture

- ✓ Gives a **standard way to think about security**
- ✓ Helps in **designing secure networks**
- ✓ Allows **systematic security planning**
- ✓ Makes security **independent of technology**

Information Security Techniques

- **Information Security Techniques** are methods and tools used to protect information from unauthorized access, misuse, modification, or destruction.
- They ensure the three basic goals of security:
- **Confidentiality**
- **Integrity**
- **Availability (CIA Triad)**

1. Cryptographic Techniques

- Used to protect data through encryption.
- **Encryption & Decryption** – Converts data into unreadable form
- **Hash Functions** – Ensure data integrity
- **Digital Signatures** – Provide authentication and non-repudiation
- **Public Key Infrastructure (PKI)** – Manages digital certificates

2. Access Control Techniques

- Restrict access to authorized users only.
- **Authentication** – Verifies user identity (passwords, biometrics)
- **Authorization** – Determines access rights
- **Role-Based Access Control (RBAC)**
- **Multi-Factor Authentication (MFA)**

3. Network Security Techniques

- Protect data while it travels through networks.
- **Firewalls** – Filter network traffic
- **Intrusion Detection/Prevention Systems (IDS/IPS)**
- **Virtual Private Networks (VPNs)**
- **Secure Protocols** – HTTPS, SSL/TLS, SSH

4. Data Protection Techniques

- Protect stored and transmitted data.
- **Data Encryption at Rest and in Transit**
- **Data Masking and Tokenization**
- **Regular Backups and Recovery**

5. Physical Security Techniques

- Protect hardware and physical infrastructure.
- **Biometric Access Control**
- **Surveillance Systems**
- **Secure Server Rooms**
- **Smart Cards & Locks**

6. Security Monitoring & Auditing

- Detect and respond to security events.
- **Log Monitoring**
- **Security Information and Event Management (SIEM)**
- **Security Audits**
- **Incident Response Systems**

7. Organizational & Policy Techniques

- Create secure behavior.
- **Security Policies**
- **User Awareness Training**
- **Incident Response Plans**
- **Regular Risk Assessment**

- **“Information security techniques combine technical controls, management policies, and physical protection to keep information safe.”**
- This statement means that **no single method is sufficient** to protect information. Effective information security requires a **layered approach** where **technology, rules, and physical safeguards work together** to protect data from threats.

1. Technical Controls

- These are **software and hardware-based security measures** that directly protect systems and data.
- They ensure:
- **Confidentiality** – by encryption, firewalls, VPNs
- **Integrity** – by hashing, checksums, digital signatures
- **Availability** – by backups, redundancy, anti-malware tools
- **Examples:**
- Firewalls blocking unauthorized access
- IDS/IPS detecting intrusions
- Encryption protecting stored and transmitted data
- Authentication systems (passwords, biometrics, MFA)
- Without technical controls, systems are open to hacking and data breaches.

2. Management Policies (Administrative Controls)

- These are **rules, procedures, and guidelines** created by management to ensure secure behavior.
- They define:
 - Who can access what
 - How data should be handled
 - What actions are allowed or forbidden
- **Examples:**
 - Information security policy
 - Password and access control policy
 - Data classification policy
 - Incident response and disaster recovery plans
 - Employee security awareness training
- Policies ensure that people use technology **correctly and responsibly.**

3. Physical Protection

- These controls protect the **hardware and physical environment** where information is stored.
- They prevent:
 - Theft of devices
 - Physical tampering
 - Unauthorized entry
- **Examples:**
 - Locked server rooms
 - CCTV and security guards
 - Biometric door access
 - Fire protection and climate control systems
- Even the best software security fails if someone can **physically steal the server.**

- Information security is effective **only when all three work together:**

- Technical Controls + Management Policies + Physical Protection



Complete Security System

- This layered approach is called **Defense in Depth**, and it ensures that if one layer fails, the others continue to protect the information.

Introduction to Cryptography

- Cryptography is a fundamental branch of computer science that deals with techniques for **secure communication in the presence of third parties called adversaries or attackers**. It provides methods to protect information from unauthorized access, modification, and misuse.
- In simple terms, cryptography converts **readable data (plaintext)** into **unreadable data (ciphertext)** so that only authorized users can access it.
- The term *cryptography* is derived from two Greek words:
 - **Kryptos** – meaning *hidden or secret*
 - **Graphein** – meaning *to write*
- Thus, cryptography literally means “**secret writing.**”

Objectives of Cryptography (Security Goals)

1. Confidentiality

- Ensures that information is accessible only to authorized users.
Example: Encrypted WhatsApp messages can only be read by the sender and receiver.

2. Integrity

- Ensures that data is not altered during transmission.
Example: Hash values are used to verify that a downloaded file is not modified.

3. Authentication

- Confirms the identity of the communicating parties.
Example: Digital certificates authenticate websites in HTTPS.

4. Non-repudiation

- Prevents a sender from denying that they sent a message.
Example: Digital signatures in online banking transactions.

Working of Cryptography (Basic Model)

1. The basic cryptographic process involves:
2. Sender takes a **plaintext message**.
3. Applies an **encryption algorithm (cipher)** with a **key**.
4. Generates **ciphertext**.
5. Ciphertext is transmitted over an insecure channel.
6. Receiver uses a **decryption algorithm** with a key.
7. Original plaintext is recovered.

Basic Terminology in Cryptography

1. Plaintext

The original readable data or message before encryption.

Example: HELLO, Password123

2. Ciphertext

The encrypted, unreadable form of plaintext.

Example: XKJ9#@1!

3. Encryption

The process of converting plaintext into ciphertext using an algorithm and key.

4. Decryption

The reverse process of converting ciphertext back into plaintext.

5. Cipher

A mathematical algorithm used for encryption and decryption.

Examples: AES, DES, RSA, Caesar Cipher.

6. Key

A secret value used by the algorithm to perform encryption and decryption.

Security depends more on the **key** than on the algorithm.

Cryptosystem

- A **cryptosystem** is a complete security system that includes:
- Plaintext
- Encryption algorithm
- Key
- Ciphertext
- Decryption algorithm
- It defines how secure communication is achieved.

Types of Cryptographic Systems-Symmetric Key Cryptography

- Uses the **same key** for encryption and decryption.
- Examples:
 - AES (Advanced Encryption Standard)
 - DES (Data Encryption Standard)
 - Blowfish
- Advantages:
 - Fast
 - Efficient for large data
- Disadvantages:
 - Key distribution problem
 - Less secure for large networks

Asymmetric Key Cryptography

- Uses **two different keys**:
- Public Key (for encryption)
- Private Key (for decryption)
- Examples:
- RSA
- Diffie-Hellman
- ECC (Elliptic Curve Cryptography)
- Advantages:
- More secure
- Solves key distribution problem
- Disadvantages:
- Slower than symmetric systems

Hash Functions

- A **hash function** converts input data into a fixed-length value called a **hash** or **message digest**.
- Properties:
- One-way function
- Same input always gives same output
- Small change in input gives large change in output
- Examples:
- MD5
- SHA-1
- SHA-256
- Used for:
- Password storage
- Data integrity checking
- Digital signatures

Digital Signatures

- A **digital signature** is a cryptographic technique used to:
- Verify sender's identity
- Ensure message integrity
- Provide non-repudiation
- It uses:
- Sender's private key to sign
- Receiver uses sender's public key to verify

Basic Cryptographic Attacks

- Some common attacks include:
- **1. Brute Force Attack**
- Trying all possible keys until the correct one is found.
- **2. Man-in-the-Middle Attack**
- Attacker secretly intercepts communication between two parties.
- **3. Ciphertext Attack**
- Attacker only has access to encrypted data.
- **4. Plaintext Attack**
- Attacker has both plaintext and corresponding ciphertext.

Importance of Cryptography

- Cryptography plays a vital role in:
- Secure communication
- Online transactions
- Digital identity
- Data privacy
- National security
- Cloud and IoT security

Introduction to Cryptanalysis

- **Cryptanalysis** is the study of techniques used to **break cryptographic systems** and recover hidden information without knowing the secret key. While cryptography focuses on creating secure systems, cryptanalysis focuses on **testing and attacking those systems** to find weaknesses.
- The main objective of cryptanalysis is to:
- Discover the **plaintext** from ciphertext, or
- Find the **secret key**, or
- Identify **vulnerabilities** in the cryptographic algorithm.
- Cryptanalysis helps in improving security by revealing flaws and guiding the design of **stronger algorithms**.

Relationship between Cryptography and Cryptanalysis

Cryptography	Cryptanalysis
Designs secure algorithms	Attempts to break them
Defensive approach	Offensive/testing approach
Focuses on protection	Focuses on attacks
Ensures privacy and security	Finds weaknesses

Together, they form the field of **cryptology**.

Types of Cryptanalytic Attacks

1. Ciphertext-Only Attack

- The attacker has access only to the encrypted message.
Goal: Guess plaintext or key using patterns or statistics.

2. Known-Plaintext Attack

- The attacker knows some plaintext–ciphertext pairs.
Goal: Derive the key or decrypt future messages.

3. Chosen-Plaintext Attack

- The attacker can choose plaintexts and obtain their ciphertexts.
Goal: Analyze encryption behavior.

4. Chosen-Ciphertext Attack

- The attacker can choose ciphertexts and obtain their plaintexts.

5. Brute Force Attack

- Tries all possible keys until the correct one is found.

Security of Cryptographic Algorithms

- The **security of an algorithm** refers to how resistant it is to cryptanalytic attacks. A secure algorithm should remain safe even if:
- The algorithm is public
- Only the key is secret
(This principle is called **Kerckhoffs's Principle**)

Factors Affecting Algorithm Security

1. Key Length

- Longer keys provide stronger security.

Example:

- 56-bit (DES) → weak
- 128/256-bit (AES) → strong

2. Algorithm Complexity

- More complex algorithms are harder to analyze and break.

3. Randomness

- Keys and random values must be unpredictable.

4. Implementation Security

- Even strong algorithms fail if implemented poorly (e.g., side-channel attacks).

Computational Security vs Perfect Security

- **Perfect Security**
 - Impossible to break even with unlimited resources.
Example: One-Time Pad (theoretically).
- **Computational Security**
 - Practically impossible to break with current technology.
Example: AES, RSA.

Evaluation of Algorithm Security

- Algorithms are evaluated using:
- Mathematical analysis
- Statistical testing
- Cryptanalysis by experts
- Time complexity of attacks

Modern Secure Algorithms

Algorithm	Type	Security
AES	Symmetric	Very strong
RSA	Asymmetric	Strong
ECC	Asymmetric	Very strong
SHA-256	Hash	Secure

Role of Cryptanalysis in Security

- Cryptanalysis is essential because it:
- Detects weak algorithms
- Improves security standards
- Validates new algorithms
- Prevents real-world attacks
- Cryptanalysis and security of algorithms are two sides of the same coin. While cryptography builds secure systems, cryptanalysis ensures their strength by continuously testing them. A cryptographic algorithm is considered secure only when it can resist **all known practical attacks**, making cryptanalysis a vital part of cybersecurity.